

ARP Spoofing como vetor de ataque DoS em redes locais: análise técnica e mitigação

IFPR — Campus Foz do Iguaçu | SEPIN 2025

Resumo

Este trabalho analisa o protocolo ARP (Address Resolution Protocol) como superfície de ataque em redes locais (LAN), com foco no vetor de negação de serviço (DoS) via envenenamento de tabelas ARP. A partir de um script Python desenvolvido em ambiente controlado, são demonstrados os mecanismos de descoberta de hosts, geração de pacotes ARP falsos e gerenciamento dinâmico de alvos por meio de threads paralelas. São discutidos os efeitos do ataque na perspectiva de cada ator da rede — vítima, atacante e roteador —, bem como as limitações estruturais do protocolo que tornam a mitigação parcial. Como contramedidas, são apontadas técnicas baseadas em ARP estático, Dynamic ARP Inspection (DAI) e segmentação de rede.

Palavras-chave: *ARP Spoofing, DoS, segurança em redes locais, envenenamento ARP, Python, Scapy.*

1. Introdução

Redes locais (LANs) são o ambiente de comunicação primário em empresas, instituições de ensino e residências. Embora a maioria das ameaças de segurança seja associada ao tráfego externo, ataques internos representam um risco igualmente significativo e frequentemente negligenciado. Entre eles, o ARP Spoofing se destaca por explorar uma característica estrutural do protocolo ARP — a ausência de mecanismo de autenticação —, permitindo que qualquer dispositivo na rede local reivindique falsamente a identidade de outro.

O protocolo ARP, definido pela RFC 826 em 1982, opera na camada de enlace e tem a função de mapear endereços IP a endereços MAC. Seu design prioriza simplicidade e eficiência, assumindo implicitamente que todos os dispositivos na rede são confiáveis. Essa premissa se torna uma vulnerabilidade crítica em ambientes onde há potencial de acesso não autorizado.

Este trabalho apresenta uma análise técnica do ARP Spoofing com foco no modo de negação de serviço (DoS), utilizando como base um script Python desenvolvido em ambiente de laboratório. O objetivo não é fornecer um guia de exploração, mas compreender o mecanismo de ataque em profundidade, condição necessária para a elaboração de estratégias de defesa eficazes.

2. Fundamentação teórica

2.1 O protocolo ARP e sua vulnerabilidade

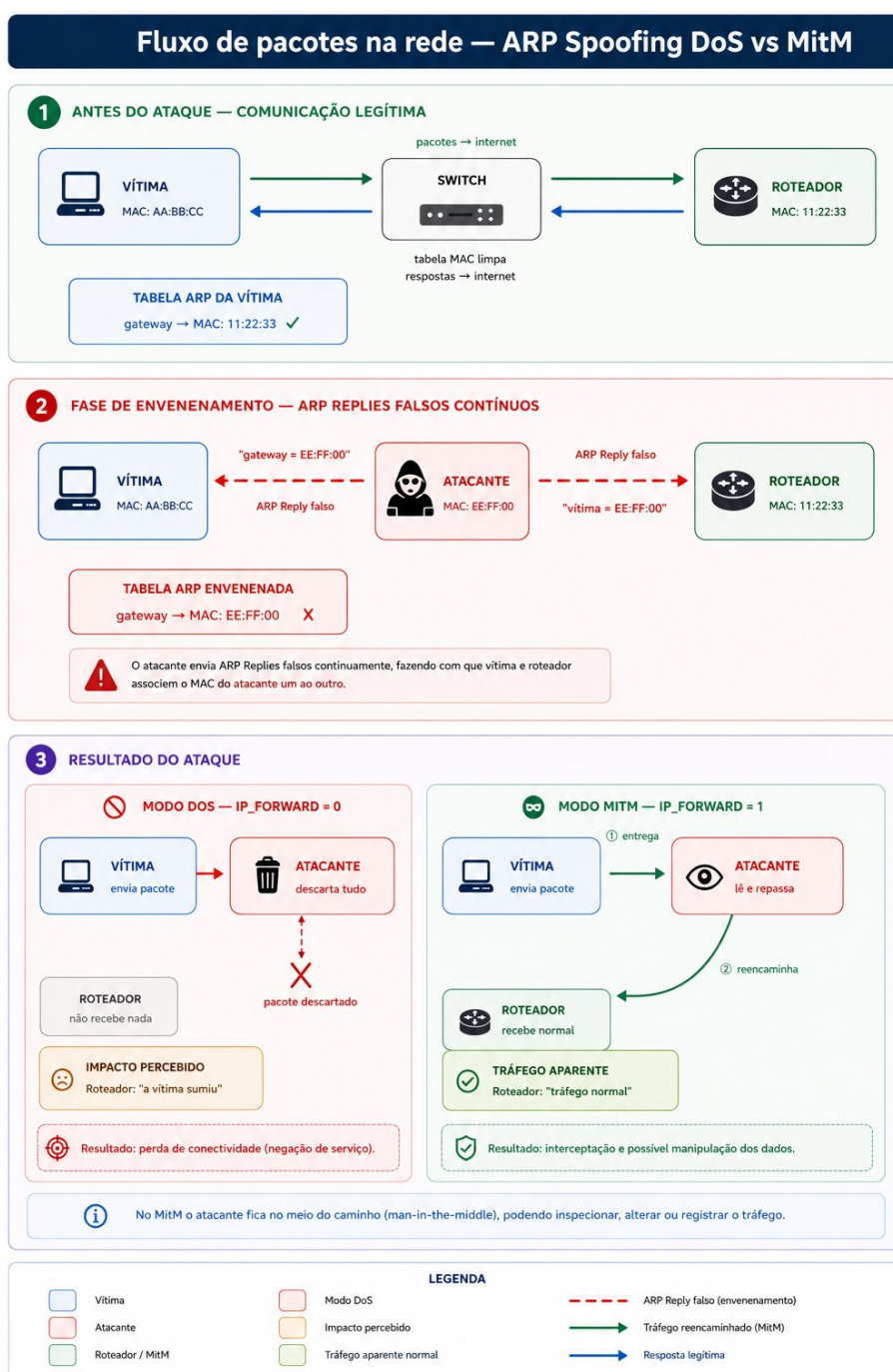
Quando um dispositivo precisa se comunicar com outro na mesma rede local, ele envia um ARP Request em broadcast perguntando "quem tem o IP X?". O dispositivo com aquele IP responde com um ARP Reply contendo seu endereço MAC. Esse mapeamento é armazenado em uma tabela ARP local, válida por um tempo determinado.

A falha fundamental está no fato de que o protocolo aceita ARP Replies não solicitados — chamados de Gratuitous ARP — sem qualquer verificação de origem. Qualquer dispositivo pode enviar um pacote afirmando que determinado IP pertence a um MAC escolhido arbitrariamente, e os demais dispositivos da rede atualizarão suas tabelas imediatamente.

2.2 Modos de ataque

O ARP Spoofing pode ser operado em dois modos principais. No modo Man-in-the-Middle (MitM), o atacante habilita o encaminhamento de pacotes no kernel (`ip_forward = 1`) e se posiciona entre a vítima e o roteador, podendo inspecionar, modificar ou registrar todo o tráfego de rede sem que a vítima perceba qualquer interrupção na conectividade.

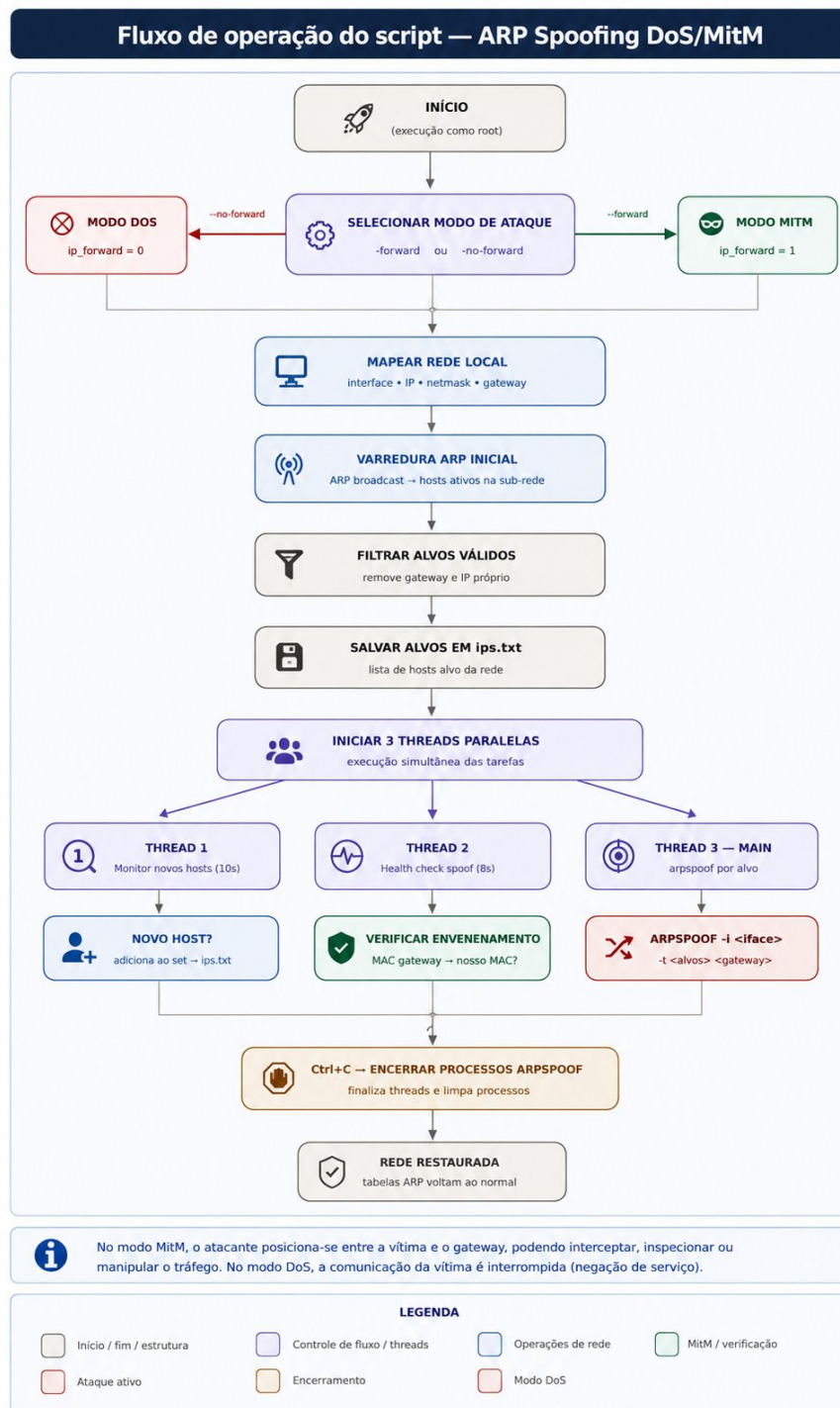
No modo DoS, foco deste trabalho, o encaminhamento é desabilitado (`ip_forward = 0`). Os pacotes enviados pela vítima chegam à máquina do atacante e são descartados silenciosamente. Para a vítima, o efeito é a perda total de conectividade com o gateway — e por consequência com a internet — sem qualquer mensagem de erro indicativa da causa real. O fluxo geral do ataque pode ser observado na Figura 1.



—FIGURA 1: Fluxo de comunicação legítima e funcionamento do ARP Spoofing nos modos DoS e MitM

3. Análise do script de ataque

O script analisado foi desenvolvido em Python e utiliza as bibliotecas Scapy (manipulação de pacotes), psutil (informações de interface de rede) e netifaces (resolução de MACs). Sua arquitetura pode ser dividida em três fases distintas. A arquitetura operacional do script é apresentada na Figura 2.



— FIGURA 2: Fluxo operacional do script utilizado para descoberta de hosts, manutenção do envenenamento ARP e gerenciamento dinâmico de alvos]

Na fase de reconhecimento, o script identifica automaticamente a interface de rede ativa, o IP local, a máscara de sub-rede e o gateway padrão. Em seguida, realiza uma varredura ARP por broadcast em toda a sub-rede para mapear os hosts ativos, filtrando o próprio IP e o gateway para evitar auto-impacto.

Na fase de ataque dinâmico, três threads são executadas em paralelo: a primeira monitora continuamente a rede em intervalos de 10 segundos para detectar e incluir novos dispositivos como alvos; a segunda realiza um health check a cada 8 segundos, verificando se o envenenamento está ativo ao comparar o MAC associado ao IP do gateway na tabela ARP da vítima; a terceira gerencia os processos arpspoof ativos, iniciando um processo separado para cada IP alvo.

Vale destacar que o script utiliza a ferramenta arpspoof para o envio contínuo dos pacotes falsos — necessário porque as tabelas ARP têm tempo de expiração, e sem renovação constante a vítima recuperaria a entrada correta em poucos minutos.

4. Impacto na rede e perspectiva dos atores

Do ponto de vista da vítima, o ataque resulta em perda total de acesso à internet. O sistema operacional não emite alertas — simplesmente os pacotes destinados ao gateway chegam ao endereço MAC errado e são descartados. Diagnósticos básicos como ping ao gateway podem continuar funcionando, pois utilizam o endereço IP diretamente na camada de rede, tornando a identificação da causa por usuários não técnicos especialmente difícil.

Do ponto de vista do roteador, o ataque é completamente invisível. Ele continua operando normalmente, recebendo apenas menos requisições originárias das vítimas, o que pode sequer ser perceptível em redes com múltiplos usuários.

Essa assimetria — impacto severo para a vítima, invisibilidade para a infraestrutura — é uma das características que tornam o ARP Spoofing DoS particularmente eficaz e difícil de detectar sem ferramentas especializadas de monitoramento.

5. Mitigação e limitações das contramedidas

A mitigação do ARP Spoofing é um problema estrutural: enquanto o protocolo ARP não possuir mecanismo de autenticação nativo, qualquer solução será uma camada de controle adicional, não uma correção definitiva. As principais abordagens disponíveis são descritas a seguir.

Entradas ARP estáticas: o mapeamento IP-MAC do gateway pode ser configurado manualmente em cada dispositivo, impedindo que ARP Replies falsos sobrescrevam a entrada. É a proteção mais simples e eficaz para dispositivos críticos, mas impraticável em redes de grande escala devido à sobrecarga administrativa.

Dynamic ARP Inspection (DAI): recurso disponível em switches gerenciáveis que valida os pacotes ARP contra uma tabela de ligações IP-MAC confiáveis (DHCP snooping binding table). Pacotes com mapeamentos inconsistentes são descartados na camada de enlace. É a contramedida mais robusta em ambiente corporativo, mas requer hardware compatível e configuração adequada.

Segmentação de rede com VLANs: ao dividir a rede em segmentos isolados, o impacto potencial de um ataque ARP é limitado ao segmento do atacante, reduzindo a superfície de ataque. Não impede o ataque, mas contém seus efeitos.

Monitoramento e detecção: ferramentas como ArpWatch e XArp monitoram mudanças nas tabelas ARP e alertam sobre mapeamentos inconsistentes. Não previnem o ataque, mas permitem resposta rápida.

É importante reconhecer que nenhuma dessas medidas elimina a vulnerabilidade de forma definitiva em todos os cenários. O protocolo ARP, por design, não possui autenticação. Propostas como S-ARP (Secure ARP) e ARPSEC já foram estudadas na literatura, mas nunca foram amplamente adotadas, principalmente pela incompatibilidade retroativa com a imensa base instalada de dispositivos legados.

6. Conclusão

O ARP Spoofing representa um vetor de ataque relevante em redes locais por explorar uma limitação estrutural de um protocolo fundamental e amplamente utilizado. A análise do script demonstrou que a execução de um ataque DoS via ARP Spoofing é tecnicamente acessível, requer apenas acesso à rede local e produz efeitos severos para as vítimas sem deixar rastros evidentes na infraestrutura.

A mitigação eficaz depende da combinação de múltiplas camadas: controle no nível do switch com DAI, segmentação por VLANs e monitoramento ativo de tabelas ARP. Em ambientes com recursos limitados, o mapeamento estático do gateway nos dispositivos críticos oferece proteção imediata com custo baixo.

Por fim, a ausência de uma solução definitiva reforça a importância da educação em segurança de redes: conhecer o mecanismo de um ataque é o primeiro passo para construir defesas conscientes e proporcionais ao risco real.

Referências

- [1] PLUMMER, D. C. An Ethernet Address Resolution Protocol. RFC 826, Network Working Group, 1982. Disponível em: <https://www.rfc-editor.org/rfc/rfc826>
- [2] BELLOVIN, S. M. Security Problems in the TCP/IP Protocol Suite. Computer Communication Review, v. 19, n. 2, p. 32–48, 1989.
- [3] CISCO SYSTEMS. Configuring Dynamic ARP Inspection. Cisco IOS Security Configuration Guide. Disponível em: <https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst6500/ios/12-2SX/configuration/guide/book/snooarp.html>
- [4] CONVERY, S.; MILLER, D. IPv6 and IPv4 Threat Comparison and Best Practice Evaluation. Cisco Systems, 2004.
- [5] SCAPY PROJECT. Scapy — Packet Manipulation Library. Disponível em: <https://scapy.net>
- [6] LOOTAH, W.; ENCK, W.; McDaniel, P. TARP: Ticket-based Address Resolution Protocol. Computer Networks, v. 51, n. 15, 2007.